

HOW TO BUILD AN IDENTITY AND ACCESS MANAGEMENT PROGRAM

A concise, practical implementation manual

Alberto (Al) Leiva

Version 1.0 - July 2026

Purpose

Use this manual for lawful, authorized, defensive work. Adapt controls to organizational risk, legal obligations, accessibility needs, and available resources.

Program foundations

- Treat identity as a security control and a business capability.
- Define authoritative sources, identity types, ownership, policies, assurance needs, and lifecycle events.
- Include employees, contractors, customers, partners, workloads, devices, service accounts, APIs, and AI agents.

Joiner, mover, and leaver lifecycle

- Create access from approved business roles and verified identity data.
- Update access promptly when duties change.
- Disable access, sessions, tokens, certificates, and physical credentials at departure.

Authentication

- Use phishing-resistant MFA for privileged and high-risk access.
- Apply risk-based authentication and secure recovery procedures.
- Protect enrollment, authenticator replacement, and help-desk resets against social engineering.

Authorization and least privilege

- Use role-based and attribute-based controls where appropriate.
- Separate incompatible duties and require approval for sensitive entitlements.
- Use just-in-time and time-limited privileged access.

Privileged and machine identities

- Vault privileged credentials and monitor administrative sessions.
- Inventory service accounts, secrets, certificates, keys, workloads, and non-human identities.
- Assign owners, rotate credentials, restrict use, and remove abandoned identities.

Access reviews and governance

- Review high-risk access more frequently.
- Give reviewers clear context and require evidence-based decisions.
- Track orphaned accounts, excessive access, toxic combinations, failed removals, and exceptions.

Federation, privacy, and roadmap

- Validate trust, claims, signing keys, redirect targets, session controls, and partner responsibilities.

- Minimize identity data and provide accessible authentication options.
- Days 1-30: inventory and leaver controls. Days 31-60: MFA, privileged access, and reviews. Days 61-90: automation, machine identity, metrics, and testing.

Implementation checklist

- ☐ Owner assigned
- ☐ Scope approved
- ☐ Inventory complete
- ☐ Risks prioritized
- ☐ Policies documented
- ☐ Controls implemented
- ☐ Evidence retained
- ☐ Exceptions expire
- ☐ Testing completed
- ☐ Management review recorded

Official references

- NIST SP 800-63-4: <https://www.nist.gov/publications/nist-sp-800-63-4-digital-identity-guidelines>
- NIST IAM Resource Center: <https://www.nist.gov/identity-and-access-management>
- NIST SP 800-207: <https://csrc.nist.gov/pubs/sp/800/207/final>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.